

and need multiple attackers coming together, who individually capture chunks of data and share it among themselves. Each chunk is then programmatically analysed to create an additional set of data in such a way that the hash of it matches that of the data chunk. In other words, for a given chunk of data and hash combination, the mathematical algorithm creates a clone data set. Further processing of the original data chunk and the resultant data set helps derive the encryption key. This attack is very time-consuming and technically complex, but can be accomplished by using multiple powerful computing machines and software programs.

Chosen dataset attacks: As discussed earlier, attackers always aim for data as well as the key, in order to completely compromise a cryptographic system. A chosen dataset method consists of two different types. In the first case, called chosen plaintext, it is assumed that the attackers have access to the original data and the encrypted version of it. The attackers then apply multiple encryption keys to the original data, and each time the output is compared with the already encrypted version. If the result is positive, it means the key is derived. In the second type of attack, called chosen cipher text, attackers have the cipher text and also the decrypted version of it. Again, the attackers try multiple keys until the output matches that of the decrypted version obtained already. These attacks are a bit less time-consuming, but need the attacker to gain an enormous amount of data and computational power for the desired results.

The SSL brute-force attack: Here, the attackers send very small data sets to be encrypted by the SSL protocol. The attackers capture the result and store it against the transmitted dataset. By doing this for lots of data chunks, a key can be eventually derived. This process is very slow, and can take days to decipher the key, and it has been found that such attacks often originate from within the firm's network. To speed up the process, this method is usually combined with the group key decipher attack.

Group key deciphering: As learnt earlier, key-based encryption is dependent on the length of the key; a bigger key requires more time to decipher. In a group key deciphering attack, multiple attackers come together—each one with a powerful machine. Unlike brute force attacks, where a lot of data is captured, in the group method only a given set of data is captured and used. This data is subjected to all possible permutations of keys to try decrypting the data. Since 256-bit encryption can take many years to decipher, using multiple powerful computing machines can bring that time down. Attackers also use statistical grouping of keys to be tried from different machines, to further quicken the process. In the past, a few such experiments showed that cracking a 128-bit key required only a few days. With improving CPU speeds and throughputs, unfortunately, cracking a 1024-bit key quickly can become a reality soon.

Compromised key attacks: Cryptography is all about trust, whereby a trusted certificate-providing authority signs a certificate. The provider itself is supposed to be extremely secure. Unfortunately, in the past, the certificate-

provider's own private key has either been exposed or stolen by attackers, who then have used this private key to sign certificates created for a domain name, which is their own site. Any browser lured to this website will not suspect such a website, because the certificate will pass the authenticity test. This happens because the public key of such certificates will already be present in the browser certificate store. This can, and in the past has, resulted in loss of personal information.

SSL DoS attacks: An attacker's main aim is usually to steal data. Since it is a troublesome and highly technical process in cryptography, a few attackers tend to use legacy methods, such as denial of service attacks. SSL negotiation adds an overhead to the TCP protocol, slowing down the communication to achieve security. In an SSL denial of service attack, the attackers establish SSL communication through a browser, and then send multiple bogus packets with varying lengths on that channel. Each packet is decrypted and processed on the server side, thus eventually exhausting CPU power, resulting in service outage. In another form, which takes place at OSI Layer 3, TCP port 443 is bombarded with bogus fragmented packets, creating a similar effect.

Protecting FOSS systems

In the FOSS world, cryptography is mainly used on Web servers by implementing the SSL protocol. Besides, open source developers can digitally sign the code before sending it to a trusted party, to prevent wire-tapping. On a Web server, the very first step is to use a digital certificate from a trusted authority. It should also have the latest and strongest cipher algorithm, and the key length should at least be 256 bits. The second step is to protect the certificate store—that crucial area on the Web server where the website's private key is stored. Only administrators and network managers should have access to it. To protect FOSS networks from brute-force attacks, other network security protection should be in place (this has already been discussed in previous articles in this series). While most critical infrastructures implement a firewall, a UTM device and powerful antivirus or anti-Trojan software, it is also imperative to have an intrusion detection system (IDS) in place. IDS systems are capable of intercepting denial of service and brute-force attacks, and also help stop other critical anomalies. In case of Linux workstations, cryptography can be used to encrypt a file or entire disk too. 

By: Prashant Phatak

The author has over 18 years of experience in the field of IT hardware, networking, Web technologies and IT security. Prashant is MCSE and MCDBA certified and is also an F5 load balancer expert. In the IT security world, he is an ethical hacker and Net-forensic specialist. Prashant runs his own firm called Valency Networks in India (<http://www.valencynetworks.com>) providing consultancy in IT security design, security audits, infrastructure technology and business process management. He can be reached at prashant@valencynetworks.com.